

Penetration Testing Report: Cyborg CTF

Target IP: 10.113.156.232

Date: July 14, 2026

Status: Completed (Root Compromise Achieved)

1. Executive Summary

During this security assessment of the **Cyborg** target machine, a full system compromise was successfully achieved. The attack vector originated from an exposed web directory containing sensitive configuration and backup files. Decompiling and extracting these backups revealed user credentials, which allowed for initial access via SSH. Once inside, an insecurely configured backup script with `sudo` privileges was exploited to perform lateral movement and gain root-level access.

2. Phase 1: Reconnaissance & Enumeration

Active Ports and Services (Nmap)

An initial port scan revealed two active services:

- Port 22/TCP: Open — OpenSSH 7.2p2 (Ubuntu Linux)
- Port 80/TCP: Open — Apache httpd 2.4.18 (Ubuntu)

Plaintext

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
```

Directory Busting (Gobuster)

A directory brute-force scan against the web server running on Port 80 identified several interesting paths, notably `/admin` and `/etc`:

Path	Status Code	Description
/index.html	200	Default Apache Ubuntu welcome page
/admin	301	Admin panel redirect

<code>/etc</code>	301	Configuration/Backup directory redirect
<code>.htpasswd</code>	403	Access denied (indicates Apache authentication is present)

3. Phase 2: Web Exploitation & Vulnerability Analysis

Information Disclosure

Exploration of the `/etc` and `/admin` directories revealed critical components of the system configuration:

- **Username Identified:** `Alex`
- **Backup Archive Found:** A Borg/tar-style backup file named `music_archive`.
- **Hash Location:** A hash file was located within the `/etc` web directory.

Credential Cracking

Using the retrieved hash (associated with the `music_archive` password), offline password cracking was conducted:

- **Archive Password Found:** `squidward`

With this password, the `music_archive` was extracted, revealing system configuration files and a cleartext password for the user `alex`.

4. Phase 3: Initial Access & Privilege Escalation

SSH Exploitation

Using the cracked credentials, an interactive SSH session was successfully established:

```
Bash
ssh alex@10.113.156.232
# Password: [Extracted Alex Password]
```

- **Result:** Successfully logged in as `alex` and retrieved `user.txt`.

Privilege Escalation (Local to Root)

An audit of current privileges using `sudo -l` showed that `alex` could run a specific backup script as `root` without providing a password:

```
Bash
User alex may run the following commands on Cyborg:
```

(ALL : ALL) NOPASSWD: /etc/mp3backups/backup.sh

Exploit Analysis

The script `/etc/mp3backups/backup.sh` accepted user-controlled flags, specifically a command-execution parameter `-c`. Because it executed arguments within a root context, it was vulnerable to command injection.

By passing `bash` to the script execution argument, the context spawned an interactive root shell:

Bash

```
sudo /etc/mp3backups/backup.sh -c "bash"
```

- **Result:** Root shell spawned.
- **Proof of Concept:** Read `/root/root.txt` to complete the compromise.

5. Remediation Recommendations

1. **Secure the Web Directory:** Remove public access to administrative directories (`/admin`) and configuration files (`/etc`). Sensitive backup archives should never be stored on a public-facing web root.
2. **Implement Strong Password Policies:** Ensure passwords for archives and user accounts are complex and resistant to offline brute-force attacks.
3. **Secure Sudo Permissions:** Restrict `sudo` permissions for scripts that allow arbitrary command execution. If a script must run as root, it should be hardened to prevent user input from being executed directly in a shell context.